CODEAXIS / ROUND 2 BUILD

# Lekhani

Brand-content review with a cited rule behind each finding and a human decision before publication.

ROUND 2 PROJECT REPORT

## Local execution audit, verified workflow record, and Round 3 handoff

| AUDIT DATE | AUDITED LOCATION | EXECUTION ENVIRONMENT |
|---|---|---|
| **25 October 2026** | Local workspace | Windows 11 / Python 3.14.7 / Node 24.22.1 |

| 155 | 0 | 0 |
|---|---|---|
| tests passed | failed | skipped |

**Overall verdict**
The guest review workflow is execution-verified in the supplied 25 October audit. Remaining gaps are clearly bounded: no public deployment or repository link, no real authentication or permanent guest storage, several integrations are not implemented, and historical quality metrics and user outcomes have not been measured.

## Built by Team Lekhani

This report updates the 24 October draft using the 25 October audit results supplied by the team. The earlier draft's evidence gaps are superseded where the new audit supplies execution evidence. Items still missing are explicitly marked not implemented, not submitted, or not measured, and are listed for Round 3 follow-up.

01 / VERDICT

# Executive summary

The local guest experience is functional, with honest boundaries around identity, storage, review authority, and publication.

**Core workflow verified working**
Guest entry, Home navigation, empty draft start, manual writing, explicit sample loading, deterministic checks, citation validation, single-occurrence terminology replacement, stale-result tracking, guest review demonstration, review-pack export/import, and TXT/text-PDF import were exercised without unhandled errors in the reported local run.

## Audit evidence basis

• The 25 October audit supplied with this request reports 155 tests passed, 0 failed, and 0 skipped using pytest 9.1.1.

• The reported environment is Windows 11, Python 3.14.7, Flask 3.1.x, in-memory SQLite, and the local project at the audited path.

• This document compiles that audit and the supplied 24 October project report. The tests were not rerun during PDF preparation; results below are attributed to the supplied audit.

• The 24 October report said implementation evidence had not been supplied. The 25 October audit adds workflow and test evidence and therefore updates that earlier status.

## Release and submission position

The local application is suitable for a Round 2 demonstration within its guest-mode limits. It is not a publicly deployed service and should not be described as production-ready or security-audited. No Git repository, remote, public deployment URL, or contribution record was supplied. Those submission details remain open.

## Project boundaries

| Area | Current position |
|---|---|
| **Guest identity** | Display name in a signed session cookie; not verified authentication. |
| **Guest drafts and decisions** | Temporary request/page state; not written as guest records to SQLite. |
| **Rule checks** | Deterministic and citation-validated; not fact-checking or legal review. |
| **Approval and publishing** | Guest review is a demonstration only; publishing happens outside the app. |

02 / PRODUCT

# Completed features and verified journey

The guest workspace is the primary Round 2 path. The separate legacy role workflow remains code-confirmed and secondary.

| Capability | Evidence | Observed behavior |
|---|---|---|
| **Guest entry** | Execution-verified | Name validation, 60-character cap, HTML escaping, guest session, slider and accessible button fallback. |
| **Navigation and gating** | Execution-verified | Guest-only pages redirect to entry without a guest; authenticated guest session reaches Home and workspace. |
| **Empty workspace** | Execution-verified | Starts blank. No draft or sample loads automatically. |
| **Fictional GreenLeaf sample** | Execution-verified | Explicit sample action, isolated lekhani-greenleaf-sample / demo-v1; five known findings in original sample. |
| **Checker and validator** | Execution-verified | Terminology, required/forbidden messaging, claim prompts; exact clause, ID, and version validation. |
| **Revision and replacement** | Execution-verified | Selected occurrence only; stale fingerprints are rejected; changed content marks results stale. |
| **Guest review** | Execution-verified | Needs changes or approved-demo label; snapshot-bound and marked outdated after relevant edits. |
| **Pack and file utilities** | Execution-verified | JSON review packs with SHA-256 text fingerprint; UTF-8 TXT and text-based PDF import. |
| **Print and Trust Lab** | Execution-verified | Print summary, citation validation examples, and isolated rule change simulator. |
| **Legacy creator/reviewer** | Code-confirmed | Role chooser and database-backed creator/reviewer workflow; secondary to the guest experience. |

## Reported end-to-end journey

1. Enter a guest name and continue to Home. 2. Open an empty workspace. 3. Explicitly load the fictional sample or write/import a draft. 4. Run checks and inspect validated findings. 5. Apply a safe single-occurrence term replacement or revise manually. 6. Recheck and confirm older results are stale. 7. Record an unverified guest review demonstration. 8. Export a review pack, optionally re-import it, then leave the workspace.

> **Sample behavior**
> The supplied audit reports exactly five findings for the original GreenLeaf sample (GLOSS-01, GLOSS-02, MSG-01, CLAIM-01, CLAIM-02), and zero findings for the revised sample. These are demo-rule outcomes, not a benchmark of general accuracy.

03 / IMPLEMENTATION

# Technology and data handling

A lean server-rendered application keeps the guest workflow portable and avoids external AI services.

| Technology | Role | Reported version / status |
|---|---|---|
| **Python** | Application runtime | 3.14.7 |
| **Flask** | Routes and server-side rendering | 3.1.x (audit reports 3.1.2 elsewhere) |
| **Jinja** | HTML templates | 3.1.6 |
| **SQLite** | Rules and legacy creator/reviewer data | Guest workflow writes no guest draft/decision rows. |
| **CSS and vanilla JavaScript** | Responsive interface and interactions | No frontend framework or bundler reported. |
| **pypdf** | Text extraction from supported PDFs | 6.2.1 |
| **pytest** | Automated test runner | 9.1.1; 155 passed per supplied audit. |
| **External AI / CDN / analytics** | External services | None reported. |

## Guest content and storage

• Draft content and review state are carried in request/response page state; the app does not keep a server-side draft cache for guests.

• The Flask signed cookie stores guest display name and, when applicable, a legacy role; no draft text, findings, or review notes are placed in it.

• The audit reports no guest writes to the database. The database is read for the fictional demo rules; legacy creator/reviewer routes use SQLite persistence.

• Only the reduced-motion preference is stored in browser localStorage. Drafts are not silently stored in localStorage or IndexedDB.

• TXT/PDF import is reported as limited to 5 MB, 10 PDF pages, and 100,000 extracted characters. Scanned PDFs do not have OCR support.

## Operating notes

The local Windows entry point is python run.py. Gunicorn is listed for POSIX deployment but cannot run natively on Windows because it requires POSIX process support (including fcntl/fork). A Linux deployment path has not been verified. The Flask development server is not a production server.

> **Privacy wording**
> If draft text is sent to Flask for checking, describe it as server-processed. Avoid saying the checker is browser-only. The supplied audit reports no full-draft logging and no draft content in URLs or cookies.

04 / RULE REVIEW

# Deterministic checking and citation safeguards

Findings are prompts tied to stored rule text. A valid citation does not establish that a finding is contextually correct.

## Supported rule categories

| Category | Behavior | Interpretation |
|---|---|---|
| **Terminology** | Whole-word, case-insensitive preferred/forbidden terms with optional replacement. | Exact match positions support inspection and controlled replacement. |
| **Messaging** | Required and forbidden phrases, scoped to supported content types; required phrases can include punctuation. | Missing required text creates a finding without an invented text span. |
| **Possible claims** | Configured regex trigger phrases for superlatives or absolutes. | Human evidence review prompt only; not a truth or legality verdict. |

## Validation sequence

Candidate finding → stable rule ID lookup → exact clause comparison → ruleset ID/version check → keep validated finding or reject it. Unknown identifiers, altered quotations, and mismatched versions are rejected and reported separately. Rejected candidates never create a misleading all-clear.

## Snapshot and freshness

The reported snapshot binds a check to the draft fingerprint, content type, audience, and rule-set reference/version. Changing text or context marks the results outdated. A stale replacement request is rejected (HTTP 409); mismatched offsets are rejected (HTTP 400). Review state is also invalidated after relevant edits.

## Coverage limitations

- Whether every factual claim is true.
- Legal compliance or certification.
- Visual brand consistency and full accessibility.
- Tone beyond the configured deterministic rules.
- Image or scanned-document content when OCR is unavailable.

05 / VERIFICATION

# Test results and what has not been measured

Execution evidence supports core local behavior. Historical evaluation targets and external user outcomes remain unmeasured.

| Check | Reported result | Evidence boundary |
|---|---|---|
| **Automated suite** | 155 passed, 0 failed, 0 skipped; exit code 0; about 12.8 seconds. | Reported command: .venv/Scripts/python -m pytest -p no:cacheprovider. |
| **Dependency consistency** | pip check passed; no broken requirements. | Reported local environment result. |
| **Guest flow** | Entry, navigation, workspace, check, review, export/import, and leave flow exercised. | Flask test client and safe in-memory assertions reported. |
| **Browser automation** | Some checks blocked. | A read-only audit could not run a script that writes temporary files/downloads under instance folders. |
| **Production server** | Not run on Linux. | Gunicorn cannot run natively on Windows; deployment behavior remains unverified. |

## Unmeasured evaluation targets

| Metric | Target in earlier report | Status |
|---|---|---|
| **Planted violation detection** | At least 8 of 10 with correct rule IDs. | Not measured; no benchmark corpus supplied. |
| **False flags on clean drafts** | At most 2 across 10 clean drafts. | Not measured; no clean-draft benchmark corpus supplied. |
| **Human review time** | Under 5 minutes per draft. | Not measured; no human timing logs supplied. |
| **User research** | External user observations. | Not submitted; no interview/usability notes supplied. |
| **Performance, availability, security outcomes** | Measured operational results. | Not measured in the supplied audit evidence. |

**Attribution**

The 155-pass result is transcribed from the team-provided 25 October audit. Tests were not independently rerun while preparing this PDF. No claim is made about tests beyond the command and environment described in that audit.

06 / OPEN ITEMS

# Not implemented, not submitted, and not measured

These are explicit handoff notes, not assumed completed work.

## Not implemented

| Item | Current state | Round 3 note |
|---|---|---|
| **Google sign-in / verified identity** | Not implemented. Guest names do not verify identity. | Add real authentication and identity-bound access. |
| **Persistent guest/cloud workspaces** | Not implemented. Guest content is temporary. | Add opt-in durable storage with user isolation. |
| **Authorised reviewer assignments** | Not implemented for guest demonstration. | Add reviewer assignment and verified decisions. |
| **Contact and issue delivery** | Not implemented. Forms are disconnected previews. | Connect delivery/storage with privacy controls. |
| **OCR for scanned PDFs** | Not implemented. Text extraction only. | Add OCR only with clear file/data handling. |
| **Welcome-page login video** | Not implemented. Current page uses CSS gradients/SVG instead. | Confirm design intent; add accessible muted media only if still required. |
| **Organisation-managed versioned rules** | Not implemented; current rules are demo/local. | Add approved rule governance, retained versions, and evidence expiry. |

## Not submitted or unavailable

- No public repository URL or Git remote was supplied; the audited folder is not a Git repository.
- No live public deployment URL was supplied. Local execution is not evidence of public availability.
- Round 2 member contribution details and role-by-role records were not supplied.
- A Linux/Gunicorn deployment verification record was not supplied.
- The prior draft's Round 1 proposal and implementation records were not included; direct plan-to-delivery comparison remains limited.

## Known security and operational finding

**LEK-SEC-01 | CSRF protection absent (P2)**
The supplied audit reports that state-changing POST endpoints accept requests without CSRF token validation or strict Origin checks. Record this as a Round 3 security-hardening item, and treat remediation as required before exposing state-changing routes to the public internet. No cross-origin multi-domain verification was supplied.

07 / HANDOFF

# Round 3 completion plan

Use these notes to close evidence gaps and deferred product work without overstating Round 2 readiness.

| Priority | Planned work | Acceptance evidence |
|---|---|---|
| **01** | Accounts and saved workspaces: real sign-in, persistent drafts, per-user access, and deliberate guest-work import. | A user saves and reopens a draft; a different user cannot access it. |
| **02** | Verified review requests: assigned reviewers, notifications, authenticated decisions, timestamps, and stale-review invalidation. | An authorised reviewer decides on the right draft; unauthorised approval is blocked. |
| **03** | Versioned brand rules and evidence: organisation-specific approved sets, retained versions, expiry tracking, and outdated-check identification. | Rule updates preserve historical references and expired evidence is flagged. |
| **04** | Security and release readiness: CSRF protection, cookie/session configuration review, production secret configuration, and Linux deployment verification. | Cross-origin state-changing requests are rejected; deployment checklist and smoke test are recorded. |
| **05** | Submission and measurement: repository/deployment links, contribution record, benchmark set, and genuine usability measurements. | Each claim is backed by a dated artifact, reproducible command, or attributed research record. |

## Suggested Round 3 release gate

- Resolve the CSRF finding before public exposure of form POST endpoints.
- Verify a production deployment on a supported Linux runtime; keep the development server local-only.
- Publish repository and deployment links and confirm what is safe to share.
- Mark performance, accuracy, accessibility, and human timing as not measured until valid evidence exists.
- Keep the guest review label clearly distinct from an authenticated organisational decision.

> **Submission language**
> Describe the current build as a locally execution-verified guest review demo. Describe Google sign-in, persistent accounts, contact/issue delivery, OCR, a login video, and organisational rule governance as not implemented. Describe public links, contribution records, user research, and benchmark metrics as not supplied or not measured. Track these items for Round 3.

## Source basis

Compiled from the team-provided 25 October 2026 read-only audit and the supplied 24 October 2026 Round 2 project report PDF. The audit is treated as the evidence source for the reported 155-test result and workflow execution. This report does not independently rerun the tests, verify a public deployment, validate individual contributions, or measure product performance.